

Simulazione di Phishing

Autore: Simone Santonico

Data: 08/05/2026

1. Scenario della simulazione

L'azienda fittizia *DataCloud Solutions* sta effettuando un aggiornamento dei sistemi di archiviazione interni.

Durante questa fase, un dipendente del reparto amministrativo riceve un'email che sembra provenire dal reparto IT.

Obiettivo dell'attacco

Ottenere le **credenziali aziendali** del dipendente per accedere al pannello cloud interno e scaricare documenti riservati.

Perché lo scenario è realistico

- Le email sugli aggiornamenti IT sono comuni.
- Il contesto aziendale rende credibile la richiesta.
- L'IT interno è percepito come affidabile.

2. Email di phishing generata con LLM

Oggetto: Azione richiesta – Aggiornamento urgente del tuo accesso DataCloud

Corpo dell'email (simulazione):

Ciao,
stiamo completando l'aggiornamento del sistema DataCloud alla nuova piattaforma sicura. Per evitare la sospensione del tuo account, ti chiediamo di confermare le tue credenziali entro le prossime **2 ore**.

Accedi al portale di verifica:

<https://datacloud-secure-auth.com/verify>

Se non completi l'aggiornamento in tempo, il tuo accesso ai documenti aziendali verrà temporaneamente bloccato.

Grazie per la collaborazione,
Team IT – DataCloud Solutions

3. Adversarial Prompt utilizzato

Per generare l'email è stato usato un prompt controllato, progettato per simulare un attacco senza creare contenuti realmente pericolosi.

Esempio di prompt (descrizione):

“Genera un'email *simulata* di phishing per scopi educativi. Deve sembrare credibile ma contenere segnali di allarme. Non creare contenuti realmente utilizzabili per attacchi.”

4. Analisi dello scenario

Perché l'email può sembrare credibile

- Linguaggio professionale.
- Riferimento a un aggiornamento reale del sistema.
- Presenza di un link apparentemente legittimo.
- Forte senso di urgenza.

5. Campanelli d'allarme (indicatori di phishing)

- Urgenza e minaccia (“sospensione dell'account”).
- Dominio sospetto.
- Richiesta di credenziali (l'IT non lo fa mai).
- Firma incompleta.
- Tono impersonale.

```
DataCloud Solutions – Access Verification Portal

[!] ATTENZIONE: Il tuo account richiede verifica

Inserisci username e password per continuare

[ Username: _____ ]
[ Password: _____ ]

[   VERIFY ACCOUNT   ]
```

INBOX - Outlook Web

From: Team IT <it-support@datacloud.com>

Subject: Aggiornamento urgente del tuo accesso

Clicca qui per verificare il tuo account

<https://datacloud-secure-auth.com/verify>

[Reply] [Forward]

6. Conclusione

La simulazione mostra come un attacco di phishing possa sfruttare:

- contesti credibili,
- urgenza artificiale,
- domini simili,
- richieste di verifica account.

L'esercizio evidenzia l'importanza della consapevolezza e della verifica delle comunicazioni interne.